

Acceso no autorizado / MFA sospechoso

Atención y escalamiento — Soporte Técnico Nivel 1

Usuario	Alejandro Mendoza
Puesto	Especialista de Soporte TI Nivel 2
Área	Soporte TI / Infraestructura y Bases de Datos
Cuenta	amendoza
Equipo	SOPORTE-L2-07
IP privada del equipo	192.168.10.47
Servidor de autenticación	192.168.10.10
Servidor de base de datos	DB-SRV-01 — 192.168.20.15
Canal de contacto inicial	Ticket de Jira
Canal de segundo contacto	Llamada telefónica de validación
Prioridad	 Alta
SLA objetivo de atención inicial	2 horas

1. Descripción del caso

Alejandro Mendoza, especialista de Soporte TI Nivel 2, reporta mediante un ticket de Jira que está recibiendo múltiples solicitudes de autenticación multifactor (MFA) que él no inició. El usuario se encuentra en su horario de comida y fuera de su estación de trabajo. Rechaza las solicitudes y solicita apoyo de Soporte Técnico Nivel 1.

La cuenta es relevante para el caso porque el usuario trabaja con infraestructura y bases de datos y cuenta con acceso autorizado a recursos corporativos sensibles. Esto no significa que se haya confirmado acceso a las bases de datos; esa situación debe investigarse por los equipos con los permisos correspondientes.

2. Señales detectadas

1. Se recibieron múltiples solicitudes MFA que el usuario no reconoce.
2. Las solicitudes ocurrieron mientras el usuario se encontraba fuera de su estación de trabajo.
3. El usuario confirmó que no estaba intentando iniciar sesión.
4. El usuario rechazó las solicitudes MFA y no reconoce la actividad.
5. Existe una posible utilización de las credenciales de la cuenta por un tercero.
6. La cuenta pertenece a un especialista de Soporte TI Nivel 2 con acceso autorizado a recursos de infraestructura y bases de datos.

7. Existe la necesidad de verificar los eventos de autenticación y los orígenes asociados mediante herramientas a las que L1 no tiene permisos administrativos.
8. Debe descartarse actividad adicional sobre servidores o bases de datos mediante una investigación especializada.

3. Prioridad, impacto y SLA

Campo	Valor
Prioridad	● Alta
Impacto	Potencial afectación de una cuenta con acceso a recursos sensibles.
Urgencia	Alta: se están generando solicitudes MFA no autorizadas en tiempo real.
Departamento afectado	Soporte TI / Infraestructura y Bases de Datos.
Equipos a involucrar	Soporte TI Nivel 1 → Soporte TI Nivel 2 → Ciberseguridad.
SLA de atención inicial	2 horas.
Justificación	El incidente requiere contención inmediata y revisión prioritaria para reducir el riesgo de compromiso de la cuenta.

4. Primer contacto — Ticket de Jira

El primer contacto se realiza mediante un ticket de Jira creado por Alejandro Mendoza. En esta etapa L1 registra el incidente y evita solicitar información sensible por el propio ticket o por correo electrónico.

Registro inicial sugerido: “Usuario reporta múltiples solicitudes MFA no reconocidas. Confirma que no está intentando iniciar sesión y que se encuentra fuera de su estación de trabajo. Se requiere validación de seguridad y contención inicial.”

5. Segundo contacto — Llamada de validación

Para obtener información adicional y realizar preguntas de seguridad, Soporte L1 contacta al usuario mediante una llamada telefónica al número registrado en los sistemas corporativos, siguiendo el procedimiento de autenticación de la organización.

Antes de continuar, L1 debe validar la identidad del usuario con los mecanismos autorizados por la empresa. No se deben pedir ni registrar contraseñas completas, códigos MFA ni secretos de autenticación.

Preguntas de seguridad

- ¿Reconoces alguna de las solicitudes MFA recibidas?
- ¿Intentaste iniciar sesión en algún servicio corporativo?
- ¿Aprobaste alguna solicitud MFA?
- ¿Cuántas solicitudes recibiste y aproximadamente a qué hora?
- ¿Has compartido tu contraseña o ingresado tus credenciales recientemente en algún sitio?

- ¿Observaste algún correo, mensaje o actividad inusual antes de recibir las solicitudes?
- ¿Tu equipo de trabajo se encontraba encendido y bloqueado?
- ¿Has detectado actividad extraña en tu cuenta?

6. Manejo de información sensible

Si durante la llamada el usuario necesita proporcionar información relacionada con la cuenta, L1 debe utilizar únicamente los canales y procedimientos seguros establecidos por la empresa.

No se debe solicitar al usuario que envíe contraseñas, códigos MFA, tokens u otras credenciales secretas mediante correo electrónico, Jira, mensajes de chat o capturas de pantalla.

Recomendación de comunicación: “Por seguridad, no compartas tu contraseña ni códigos MFA por correo, Jira o mensajería. Nosotros te indicaremos el canal seguro y el procedimiento autorizado para cualquier validación necesaria.”

7. Respuesta de Soporte Técnico Nivel 1 — Paso a paso

1. Recibir y clasificar el ticket como incidente de seguridad relacionado con acceso/MFA.
2. Confirmar con el usuario que las solicitudes MFA no fueron iniciadas por él.
3. Indicar inmediatamente que no apruebe ninguna solicitud MFA inesperada.
4. Solicitar que rechace las solicitudes pendientes.
5. Realizar la validación de identidad mediante el procedimiento autorizado, sin solicitar secretos completos.
6. Preguntar si el usuario aprobó alguna solicitud o si ingresó sus credenciales recientemente.
7. Registrar fecha, hora, cantidad de solicitudes y demás información necesaria para la investigación.
8. Proteger la cuenta conforme al procedimiento corporativo; si corresponde, solicitar o ejecutar mediante las herramientas autorizadas el cambio de contraseña.
9. Solicitar el cierre de sesiones activas cuando el procedimiento y las herramientas disponibles lo permitan.
10. Documentar las acciones realizadas y conservar la evidencia disponible sin exponer información sensible.
11. Escalar el caso a Soporte TI Nivel 2 para la revisión de eventos de autenticación en Active Directory.
12. Informar a N2 que la cuenta tiene acceso autorizado a recursos de infraestructura y bases de datos.
13. Solicitar a N2 que determine si existen eventos de autenticación no reconocidos, bloqueos o posibles orígenes asociados.
14. Si N2 identifica indicadores que requieren investigación especializada, escalar a Ciberseguridad.
15. Dar seguimiento al usuario y mantener el ticket actualizado.

8. Escalamiento a Soporte TI Nivel 2

L1 no cuenta con permisos administrativos para realizar una investigación avanzada en Active Directory. Por ello, el ticket se escala a N2.

Solicitud a N2: “Validar los eventos de autenticación de la cuenta amendoza durante el periodo correspondiente al incidente, revisar intentos no reconocidos, bloqueos y posibles orígenes o equipos asociados. Correlacionar la información con los eventos MFA disponibles.”

N2 deberá documentar sus hallazgos en el ticket o mediante el canal interno autorizado, evitando incluir contraseñas, códigos MFA u otros secretos.

9. Escalamiento a Ciberseguridad

El caso se escala a Ciberseguridad cuando existe evidencia o indicios suficientes para requerir una investigación especializada. La cuenta tiene acceso a recursos sensibles, por lo que es necesario descartar actividad adicional.

- Revisar y correlacionar eventos de autenticación, MFA y otros registros disponibles.
- Determinar si hubo autenticaciones exitosas o intentos repetitivos.
- Analizar los orígenes, dispositivos y sesiones relacionados.
- Revisar, mediante los registros autorizados, si existió actividad relevante sobre servidores o bases de datos.
- Determinar el alcance y la naturaleza del incidente.
- Definir acciones adicionales de contención o recuperación.

10. ¿Por qué se utiliza MFA como capa adicional?

MFA añade una segunda capa de verificación a la contraseña. Si un tercero obtiene o utiliza una contraseña comprometida, todavía puede encontrarse con el segundo factor, que en este caso requiere la aprobación del usuario.

Credenciales comprometidas → Intento de acceso → MFA → Usuario rechaza → Acceso no completado

El MFA no significa que una cuenta sea invulnerable. Una solicitud inesperada puede ser una señal de que las credenciales podrían estar siendo utilizadas o probadas, por lo que debe investigarse.

11. Posibles causas a investigar

No se debe asumir cuál ocurrió. Ciberseguridad deberá investigarlo. Entre las posibilidades se encuentran:

- Phishing o robo de credenciales mediante sitios falsos.
- Ingeniería social.
- Reutilización de credenciales expuestas en otro servicio.
- Malware o compromiso de un dispositivo.
- Exposición o almacenamiento inseguro de credenciales.

12. Evidencia y trazabilidad

La documentación debe conservar una línea temporal como la siguiente:

Hora	Fuente	Evento	Responsable
------	--------	--------	-------------

14:07	Usuario/MFA	Primera solicitud no reconocida	Usuario
14:07–14:08	MFA	Múltiples solicitudes rechazadas	Usuario
14:10	Jira	Ticket reportado a L1	Usuario/L1
14:12	Llamada	Validación de identidad y preguntas de seguridad	L1
14:15	Jira	Contención y documentación inicial	L1
14:20	Active Directory	Revisión de eventos solicitada	N2
Posterior	Seguridad	Investigación especializada	Ciberseguridad

13. Mensaje de seguimiento al usuario

Mensaje sugerido: “Hola, Alejandro. Recibimos tu reporte y confirmamos que las solicitudes MFA no fueron iniciadas por ti. Te recomendamos no aprobar ninguna solicitud inesperada y no compartir contraseñas ni códigos MFA por correo, Jira o mensajería. Ya realizamos la contención inicial y escalamos el caso a Soporte TI Nivel 2 para la revisión correspondiente. Ciberseguridad será involucrado si la investigación identifica indicadores que lo requieran.”

14. Recomendación al usuario

“Nunca apruebes una solicitud MFA que no hayas iniciado. Si recibes una solicitud inesperada, recházala y repórtala inmediatamente a Soporte TI; tampoco compartas contraseñas o códigos MFA por correo o mensajería.”

15. Resultado esperado del proceso

L1: detecta, contiene, valida, documenta y escala.

N2: revisa los eventos de autenticación y Active Directory conforme a sus permisos. **Ciberseguridad:** investiga el posible incidente, correlaciona fuentes y determina alcance y acciones adicionales.

16. Conclusión

La recepción de solicitudes MFA no reconocidas constituye un indicador que debe ser atendido con prioridad. Soporte Técnico Nivel 1 no necesita ni debe realizar una investigación avanzada fuera de sus permisos: su función es proteger al usuario, evitar que autorice solicitudes sospechosas, recopilar la información necesaria, documentar y escalar. Soporte Nivel 2 puede revisar los eventos de autenticación mediante Active Directory, mientras que Ciberseguridad puede realizar la investigación especializada y correlacionar la actividad de autenticación con otros recursos corporativos.